



Детекција, инцидент и рањивости

Од безбедносног сигнала до проверљиве и одмерене реакције

Проблем који решавамо

Безбедносни догађај није аутоматски инцидент. Систем најпре препознаје сигнал, затим га ставља у контекст и тек онда одређује да ли је потребна реакција. Такав ток спречава и игнорисање проблема и непотребно алармирање због сваког одступања.

ПРОБЛЕМ

Шта може поћи по злу

Безбедносни догађај није аутоматски инцидент. Систем најпре препознаје сигнал, затим га ставља у контекст и тек онда одређује да ли је потребна реакција. Такав ток спречава и игнорисање проблема и непотребно алармирање због сваког одступања.

ЗАШТО

Зашто је тема важна

Управљање инцидентом даје структуру тренутку када је најлакше изгубити контекст. Рањивост постаје решив проблем када је повезана са имовином, приоритетом, власником и доказом да је корекција проверена.

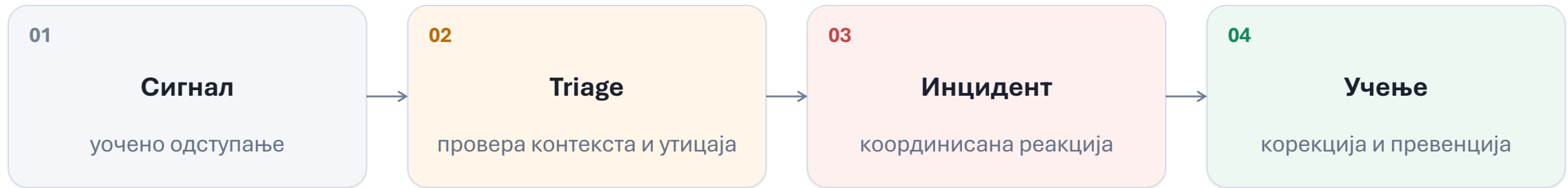
ИСХОД

Шта треба доказати

Одлука је јасна, примењује се на серверу и оставља поновљив доказ успешног и одбијеног исхода.

Четири појма граде једну одлуку

Сваки елемент одговара на друго питање и оставља другачији доказ.



КЉУЧНА ПОРУКА

Није сваки сигнал инцидент, али сваки значајан исход оставља знање корисно за следећу одлуку.

Сигнал

уочено одступање

01

Праг детекције треба да има смисао и разлог, не само произвољну бројку.

Питање: који улаз покреће ову одлуку?

02

Детекција треба да опише образац који је вредан пажње, а не да сваку грешку прогласи инцидентом.

Питање: која граница мора бити видљива?

03

Праг се бира према нормалном понашању система, а не према случајном броју.

Питање: који доказ остаје после исхода?

ПИТАЊЕ ЗА ДИСКУСИЈУ

Који догађај би у вашем систему био користан сигнал, али не и довољан доказ инцидента? Који контекст недостаје?

Triage

провера контекста и утицаја

01

Затварање упозорења чува образложење, јер је то знање за следећи сличан случај.

Питање: који улаз покреће ову одлуку?

02

Triage чува одлуку и образложење, укључујући разлог због ког је упозорење затворено.

Питање: која граница мора бити видљива?

03

Упозорење има озбиљност, власника и рок до ког се мора погледати.

Питање: који доказ остаје после исхода?

ПИТАЊЕ ЗА ДИСКУСИЈУ

Који догађај би у вашем систему био користан сигнал, али не и довољан доказ инцидента? Који контекст недостаје?

Инцидент

координисана реакција

01

Рањивост није решена променом статуса, већ провером да је ризик заиста смањен.

Питање: који улаз покреће ову одлуку?

02

Затварање рањивости тражи доказ да је изложеност уклоњена или прихваћена уз видљив преостали ризик.

Питање: која граница мора бити видљива?

03

Инцидент се отвара када контекст покаже стварни утицај или вероватну злоупотребу.

Питање: који доказ остаје после исхода?

ПИТАЊЕ ЗА ДИСКУСИЈУ

Који догађај би у вашем систему био користан сигнал, али не и довољан доказ инцидента? Који контекст недостаје?

Учење

корекција и превенција

01

Праг се бира према нормалном понашању система, а не према случајном броју.

Питање: који улаз покреће ову одлуку?

02

Упозорење има озбиљност, власника и рок до ког се мора погледати.

Питање: која граница мора бити видљива?

03

Инцидент се отвара када контекст покаже стварни утицај или вероватну злоупотребу.

Питање: који доказ остаје после исхода?

ПИТАЊЕ ЗА ДИСКУСИЈУ

Који догађај би у вашем систему био користан сигнал, али не и довољан доказ инцидента? Који контекст недостаје?

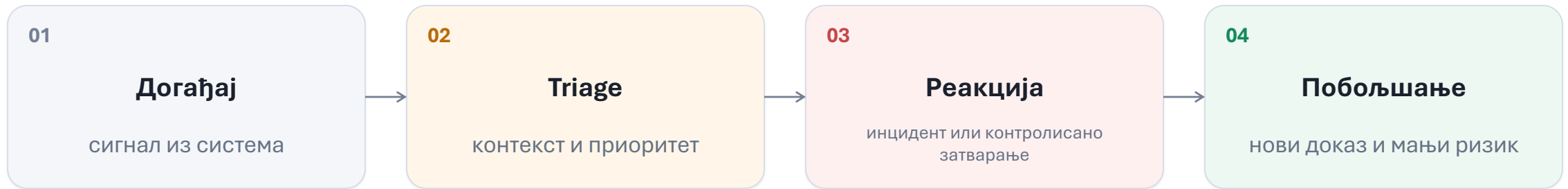
Сигнал, alert и инцидент

Поређење служи да се разлике виде без тешке табеле и ситног текста.

Стање	Шта представља	Потребна реакција
Сигнал	Сиров догађај или одступање.	Сачувати контекст и проверити правило.
Alert	Сигнал који је прешао дефинисан праг.	Triage и процена приоритета.
Инцидент	Потврђен или вероватан безбедносни утицај.	Координисана реакција и следљив ток.
Налаз рањивости	Потенцијална изложеност коју треба проценити.	Власник, рок и доказ корекције.

Шема одговора на безбедносни догађај

Није сваки сигнал инцидент, али сваки значајан исход оставља знање корисно за следећу одлуку.



ЗАДАТАК

За сваки корак наведите ко га покреће, ко доноси одлуку и који траг остаје.

Ток управљања рањивошћу

Од описа проблема до одлуке која може да се провери.

КОНТЕКСТ

Ток управљања рањивошћу

Налаз постаје користан тек када се повеже са стварном имовином и њеном изложеношћу. Исти технички проблем нема исти приоритет на изолованом развојном рачунару и на јавно доступној услузи која обрађује осетљиве податке.

01

Потврдити да се налаз односи на стварну компоненту и активну верзију.

02

Процени утицај у контексту доступности, података и граница поверења.

03

Одредити корекцију, компензациону контролу или образложено прихватање ризика.

04

Затворити налаз тек када постоји доказ да је изложеност проверено смањена.

Сигнал тражи контекст

Три правила која треба да остану видљива у имплементацији и ревизији.

01

**Праг детекције треба да има
смисао и разлог, не само
произвољну бројку.**

Јасно правило

02

**Затварање упозорења чува
образложење, јер је то знање за
следећи сличан случај.**

Проверљива примена

03

**Рањивост није решена
променом статуса, већ
провером да је ризик заиста
смањен.**

Видљив доказ

Како се ова тема види у развоју

Тема се види у малим одлукама током развоја, не само у завршној документацији.

РАЗВОЈНИ КОНТЕКСТ

Од принципа до радног кода

Тим бира мали број сигнала који су разумљиви оператеру. За сваки описује нормално понашање, разлог активирања, одговорну особу и безбедан начин провере. Тако се детекција дизајнира као производна могућност, а не као споредни лог.

01

Именуј одлуку и њену границу.

02

Имплементирај проверу на серверу.

03

Додај позитиван и негативан доказ.

Пример: више неуспелих пријава

Конкретан случај показује где опште правило постаје стварна одлука система.

СЦЕНАРИО

Пример: више неуспелих пријава

Низ неуспелих пријава може значити погрешно запамћену лозинку, проблем интеграције или покушај злоупотребе. Сам број неуспеха зато није довољан за закључак. Triage додаје контекст: да ли су покушаји дошли са истог извора, да ли се односе на осетљиве налоге и да ли се образац наставља након упозорења.

01

Детекција треба да опише образац који је вредан пажње, а не да сваку грешку прогласи инцидентом.

02

Triage чува одлуку и образложење, укључујући разлог због ког је упозорење затворено.

03

Затварање рањивости тражи доказ да је изложеност уклоњена или прихваћена уз видљив преостали ризик.

Triage додаје контекст пре отварања инцидента

Код почиње од исте леве ивице као наслов прозора и остаје читљив на пројектору.

```
1 public TriageResult Triage(Alert alert, Asset asset)
2 {
3     if (alerts.IsDuplicate(alert.Fingerprint))
4         return TriageResult.MergeWithExisting();
5     var severity = risk.Score(alert.Signal, asset.Criticality);
6     if (severity < Threshold.Medium)
7         return TriageResult.Close("below_threshold");
8     return incidents.Open(alert, asset, severity);
9 }
```

ШТА ЈЕ ВАЖНО

Дупликати, критичност имовине и праг реакције спречавају да сваки сигнал постане нови инцидент.

ГРАНИЦА

Одбијање је експлицитан исход са разлогом који се може тестирати и објаснити.

Поновљени alert не сме да умножи рад

Негативан тест није споредан случај — он описује где право престаје.

```
1 [Fact]
2 public void Duplicate_alert_does_not_create_second_incident()
3 {
4     alerts.Store(Alert.WithFingerprint("login-spike:u-3"));
5
6     var result = triage.Handle(Alert.WithFingerprint("login-spike:u-3"));
7
8     result.Action.Should().Be("merge");
9     incidents.Created.Should().Be(0);
10 }
```

ДОКАЗ

Негативан сценарио проверава идемпотентност и чува једну временску линију догађаја.

ПРОВЕРА

Промените једну чињеницу и очекујте јасан, стабилан разлог одбијања.

Доказ мора да одговори шта се догодило

Чува се довољно контекста за реконструкцију, али не и тајне или непотребни лични подаци.

```
1 {  
2   "signal": "login_failure_spike",  
3   "asset": "admin-portal",  
4   "severity": "high",  
5   "owner": "security-on-call",  
6   "status": "investigating",  
7   "correlationId": "inc-2026-041"  
8 }
```

ДОВОЉНО

Актер, радња, циљ, исход и разлог

Временска ознака и correlation ID повезују траг са остатком тока.

НЕ ПРИПАДА У ДОКАЗ

Лозинка, token, тајна и сувишан садржај

Траг не сме да постане нови извор цурења или збирка непотребних података.

Три грешке које треба препознати одмах

Свака делује практично у првој итерацији, али касније постаје скривена безбедносна граница.

01

Упозорење без власника и правила за triage.

Нема јасног власника одлуке.

02

Аутоматско затварање без доказа о решавању узрока.

Не постоји негативан сценарио.

03

Скенирање зависности без одлуке како се налаз процењује и прати.

Доказ не показује стварни исход.

Учење након догађаја

Добар доказ је свеж, поновљив и довољно јасан да га други члан тима протумачи.

ОБРАЗЛОЖЕЊЕ

Учење након догађаја

Добар пост-инцидент преглед није потрага за особом која је погрешила. Његов циљ је да пронађе где су недостајали сигнал, заштитна провера, јасна одговорност или припрема за опоравак. Резултат треба да мења систем или процес на начин који се може проверити.

01

Хронологија одваја чињенице од претпоставки насталих под притиском.

02

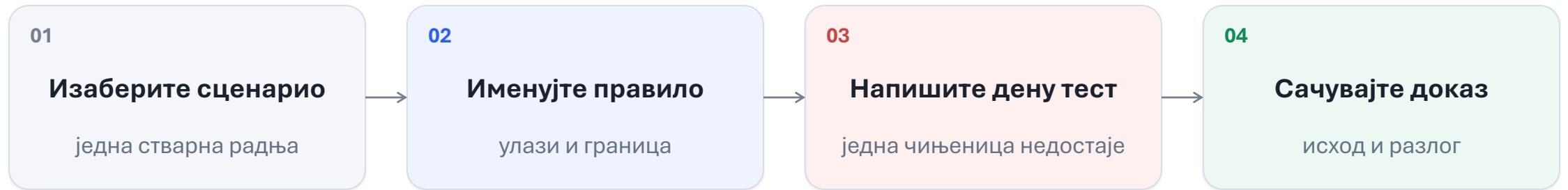
Акције након инцидента имају власника и проверљив завршетак.

03

Нови сценарио се додаје у тестове или оперативне вежбе, како се исто знање не би изгубило.

Мини вежба за пројекат

На једном сценарију повежите одлуку, имплементацију, негативни тест и доказ.

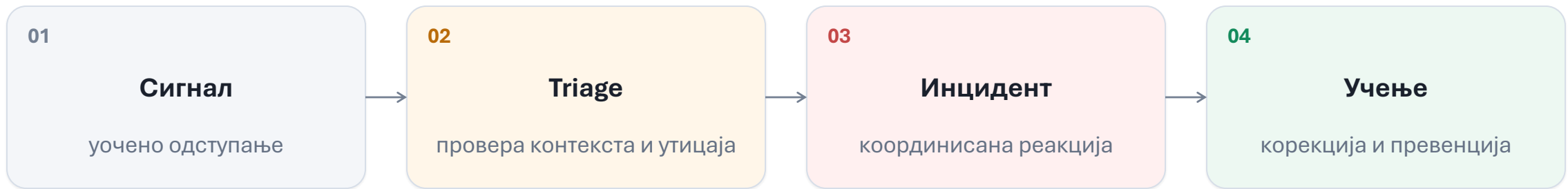


ЗАДАТАК ЗА ПРОЈЕКАТ

Примените тему „Детекција, инцидент и рањивости“ на додељену пројектну целину и припремите доказ који други члан тима може да понови.

Провера разумевања

Тема је савладана када одлуку можете да објасните без ослањања на назив framework-a.



ЗА ЗАВРШЕТАК

Који догађај би у вашем систему био користан сигнал, али не и довољан доказ инцидента? Који контекст недостаје?

Следећи корак: применити исти модел на једну реалну границу у сопственом пројекту.